

JurisControl — Relatório de Segurança

Pentest caixa-preta · recon passivo + enumeração não-destrutiva · alvo `https://juriscontrol.app.br`

Data: 08/06/2026

Escopo: OSINT + recon não-intrusivo

Autorização: engajamento p/ cliente

Setor: SaaS jurídico (LGPD Art.11)

Impacto no serviço: zero

SUMÁRIO EXECUTIVO

Postura geral: MÉDIA-BAIXA — atenção urgente. A camada de transporte é sólida (TLS 1.2/1.3, HSTS, sem segredos vazados no front, sem source maps). Todo o risco material está concentrado na **camada de autorização do backend Supabase** — exatamente o ponto de falha nº1 da stack Lovable+Supabase.

exfiltração total da base multi-tenant

`signup aberto + RLS não confirmado`

O achado de maior severidade (RLS) **não foi confirmado na prática de propósito**: verificá-lo exige consultar a base de produção do cliente, o que está fora do escopo não-destrutivo. É, ao mesmo tempo, o **maior risco e a maior incerteza** — só o teste ativo (com sign-off) fecha o veredicto.

1

CRÍTICO

3

ALTO

7

MÉDIO

BAIXO / INFO

6

POSITIVOS

STACK & FINGERPRINT

FRONTEND SPA React/Vite gerado no **Lovable.dev** (bundle 1,47 MB, sem source map)

EDGE / CDN **Cloudflare** (origin provável Vercel)

BACKEND **Supabase** — projeto `gyhcgxcmjaeaycqkdhvg.supabase.co` (PostgREST + Auth + Edge Functions + Storage)

PAGAMENTO Nexano (`checkout.nexano.com.br`)

AUTH Email-only · sem OAuth · sem CAPTCHA · sem passkeys · SMS provider Twilio (phone off)

TELEMETRIA Lovable analytics + **session replay** (`/__15e/events.js`) ativo em produção

■ MAPA DA SUPERFÍCIE DE ATAQUE

Extraído estaticamente do bundle JS (sem tocar a base). Define o alvo do teste ativo.

EDGE FUNCTIONS (10)

`submit-public-ficha` ⚠️ unauth

`validate-ficha-token` ⚠️ unauth

`admin-create-user`

`admin-update-user`

`manage-subscription`

`analyze-document`

`generate-ai-context`

`generate-ai-document`

`fetch-process-data`

`import-process`

STORAGE BUCKETS (3)

`documents` · PRIVADO ✓

`office-logos` · público

`offices` · privado ✓

RPCS (2)

`get_office_profiles`

`get_ai_usage_current_month`

TABELAS EXPOSTAS VIA POSTGREST (21) – SUPERFÍCIE DO RLS

`clients`

`casos`

`processes`

`documents`

`fees`

`profiles`

`ficha_compartilhamento`

`deadlines`

`deadline_history`

`events`

`notifications`

`offices`

`process_movements`

`process_notes`

`processos_atualizacao`

`document_templates`

`ai_document_generations`

`relatorios_iniciais`

`status_changes`

`subscriptions`

`timeline_entries`

■ ACHADOS – POR SEVERIDADE

CRÍTICO

C-01

21 tabelas expostas diretamente ao cliente via PostgREST. Se **uma única** não tiver Row Level Security escopada por `office_id`, qualquer usuário autenticado lê/escreve dados de **todos os escritórios**.

VETOR

Conta gratuita (ver A-01) → JWT `authenticated` → query direta ao PostgREST

IMPACTO

Exfiltração da base inteira, multi-tenant. Irreversível. Sigilo advogado-cliente + PII Art.11.

STATUS

Não testado (fora do escopo não-destrutivo) — confirmar via Supabase Security Advisor ou teste cruzado autorizado.

ALTO

A-01

`/auth/v1/settings` confirma `disable_signup:false` + `mailer_autoconfirm:true`. Qualquer pessoa cria conta autenticada instantânea, sem verificar e-mail. É o "pé na porta" que torna o C-01 explorável por estranhos — a combinação A-01 + C-01 é o vetor crítico real.

ALTO

A-02 · N-01

`submit-public-ficha` e `validate-ficha-token` confirmadas vivas (OPTIONS 200, CORS `*`), alimentando a tabela `ficha_compartilhamento` e o link `/ficha/:token`. Superfície **anônima** → IDOR / brute-force de token fraco (acesso a fichas de qualquer escritório) + insert/spam não-autenticado sem rate-limit aparente.

ALTO

A-03

`admin-create-user`, `admin-update-user`, `manage-subscription` alcançáveis de qualquer origem. Se não revalidarem o papel do chamador **server-side** → escalonamento de privilégio (criar admin, alterar plano). Requer teste de invocação (sign-off).

MÉDIO

N-02

Nenhuma defesa de bot em auth. Combinado com A-01: criação de contas em massa, credential stuffing, enumeração.

MÉDIO

N-03

`analyze-document`, `generate-ai-document`, `generate-ai-context`: se a cota (`get_ai_usage_current_month`) não for imposta server-side → abuso de LLM / custo. Documentos não-confiáveis processados → vetor de prompt injection.

MÉDIO

N-04

`import-process` / `fetch-process-data` fazem fetch server-side de dados externos. Se o identificador/URL for controlável pelo atacante → SSRF / acesso à rede interna.

MÉDIO

N-05

Se for `SECURITY DEFINER` sem escopo de `office_id` → vazamento de perfis/e-mails entre escritórios. Requer teste ativo.

MÉDIO

M-01/02/03

CSP, X-Frame-Options e Permissions-Policy totalmente ausentes. Presentes: HSTS+includeSubDomains, Referrer-Policy, X-Content-Type-Options.

MÉDIO

M-04

Sessão guardada em `localStorage` num SPA sem CSP → qualquer XSS = sequestro completo de sessão.

MÉDIO

N-06

Sem `X-Frame-Options` nem CSP `frame-ancestors` → app embutível em iframe (UI redress / clickjacking de ações autenticadas).

INFO

N-07 · ENV

Supabase REST com `Access-Control-Allow-Origin: *` (default; amplifica risco se token for roubado). Anon key + URL do projeto no bundle (público por design). Token inline = metadado de build do Lovable (`project_id` + `commit_sha`). **Nenhum segredo sensível vazado.**

- ▶ Bucket `documents` (docs jurídicos) é **PRIVADO** — o pesadelo de LGPD está mitigado.
- ▶ Nenhuma `service_role` key vazada no front (verificado byte a byte no bundle).
- ▶ Sem source maps — código não reconstruível.
- ▶ HSTS com `includeSubDomains` — transporte forçado em HTTPS.
- ▶ Sem secrets de terceiros (Stripe/Google/OpenAI/AWS/GitHub) no bundle ou HTML.
- ▶ CORS do app não reflete origem maliciosa.

■ EXPOSIÇÃO LGPD

sensíveis (Art. 11) sigilo advogado-cliente C-01 A-02
session replay do Lovable notificável à ANPD (Art. 48)

■ AÇÃO IMEDIATA RECOMENDADA AO CLIENTE

- 1 Rodar o Supabase Security Advisor `office_id`
(resolve a incerteza do C-01 em minutos, sem teste externo)
- 2 Fechar/endurecer o signup
- 3 Revisar autorização server-side `admin-*` `manage-subscription`
- 4 Auditar o token /ficha `submit-public-ficha`
- 5 Adicionar headers `X-Frame-Options: DENY`
- 6 Impor cota das funções de IA

■ NÃO EXPLORADO — REQUER SIGN-OFF PARA TESTE ATIVO

- ▶ **RLS data-access (C-01)** — teste cruzado com 2 contas: o que define o engajamento.
- ▶ **Authz interna das Edge Functions** — invocar `admin-*` como usuário comum/anônimo.
- ▶ **Token /ficha** — entropia/brute (validate-ficha-token) + insert via submit-public-ficha.
- ▶ **Auth** — rate-limit em login/reset, enumeração de e-mail, open-redirect em `redirect_to`, força de senha, abuso de refresh/JWT.
- ▶ **Prompt injection** real nas funções de IA + verificação da imposição de cota.
- ▶ **SSRF** em import-process / fetch-process-data.

Conduta do teste. Todo o assessment foi **não-destrutivo**: apenas OSINT, leitura de páginas públicas, headers, análise estática do bundle e enumeração via OPTIONS/GET. Zero ações destrutivas, zero exfiltração de dados de usuários, zero brute-force, zero impacto no serviço. Achados marcados "requer teste ativo" só serão executados mediante autorização escrita do cliente.